AUTHENTICATION & AUTHORIZATION SERVICE

Final Database Schema

MULTI-SELLER | ROLE-BASED | TENANT-ISOLATED | JWT / SESSION MANAGEMENT

DELIVERABLE	Database Schema Finalization
VERSION	1.0
DATE	October 2026
SCOPE	Identity, seller onboarding, customer accounts, RBAC, tenant isolation and secure sessions

14	Tables	**6**	Roles	**4**	Access tables	**2**	Token tables

DESIGN PRINCIPLES
Authentication identifies the account. Authorization enforces role and permission access. Seller context enforces tenant-level data isolation.

Overview & Requirements

The service is organized into identity tables, seller-specific customer tables, access-control tables, verification data and session/token tables.

Requirements

- Super Admin, Admin, Accountant, Seller and Customer Care have dedicated account tables.
- Seller Users are scoped to a seller using seller_id.
- The same email can be used for different sellers, but not twice under the same seller.
- A seller-scoped user must never access another seller tenant.
- Authentication fields include email, mobile number, password hash and profile photo where required.
- Seller includes business name, business logo and GST ID.
- Seller verification includes MSME and required business documents.
- Users can have multiple addresses through a separate user_addresses table.
- JWT-based authentication is supported with refresh-token/session management.

Role & Creation Hierarchy

Role	Creation / ownership
SUPER_ADMIN	Global account. Can create ADMIN, ACCOUNTANT and SELLER.
ADMIN	Platform administration within assigned privileges. Can create/maintain SELLER where authorized.
ACCOUNTANT	Accounting operations. No initial account creation responsibility.
SELLER	Business/tenant account. Creates and manages SELLER_USER accounts.
CUSTOMER_CARE	Customer support account. Access is permission-controlled.
SELLER_USER	Customer/user account scoped to a single seller.

Table Inventory

Identity	Access	Session
1. super_admins	6. seller_user_roles	12. refresh_tokens
2. admins	7. roles	13. jwt_tokens
3. accountants	8. permissions	
4. sellers	9. role_permissions	
5. customer_care	10. user_addresses	
	11. seller_verifications	
	Seller users are stored in seller_users	

Key Relationships

Relationship	Rule
sellers -> seller_users	One seller can have many seller users
seller_users -> user_addresses	One seller user can have many addresses
sellers -> seller_verifications	One current verification record per seller
seller_users <-> roles	Many-to-many through seller_user_roles
roles <-> permissions	Many-to-many through role_permissions

Part 1 - Identity Tables

Key: PK = primary key, FK = foreign key, UNIQUE = uniqueness constraint. ID columns use UUID or BIGINT consistently.

1 super_admins — Global account

Global platform account. No public signup.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Account display name
email	VARCHAR(255)	Login email
mobile_number	VARCHAR(20)	Mobile number
password_hash	VARCHAR(255)	Secure password hash; never store plain password
profile_photo	VARCHAR(500)	Profile photo URL/path
is_active	BOOLEAN	Account active/inactive
created_at	TIMESTAMP	Account creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

2 admins — Created by Super Admin

Admin account created by authorized Super Admin.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Account display name
email	VARCHAR(255)	Login email
mobile_number	VARCHAR(20)	Mobile number
password_hash	VARCHAR(255)	Secure password hash; never store plain password
profile_photo	VARCHAR(500)	Profile photo URL/path
created_by	UUID / BIGINT	FK -> super_admins.id (creator)
is_active	BOOLEAN	Account active/inactive
created_at	TIMESTAMP	Account creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

Part 1 - Identity Tables (continued)

3 accountants — **Created by Super Admin**

Accounting-team account created by Super Admin.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Account display name
email	VARCHAR(255)	Login email
mobile_number	VARCHAR(20)	Mobile number
password_hash	VARCHAR(255)	Secure password hash; never store plain password
created_by	UUID / BIGINT	FK -> super_admins.id (creator)
is_active	BOOLEAN	Account active/inactive
created_at	TIMESTAMP	Account creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

4 sellers — **Tenant account**

Business/tenant account. Seller may register, but full portal access depends on verification status.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Seller account name
email	VARCHAR(255)	Seller login email
mobile_number	VARCHAR(20)	Seller mobile number
password_hash	VARCHAR(255)	Secure password hash
profile_photo	VARCHAR(500)	Seller profile photo URL/path
logo	VARCHAR(500)	Business logo URL/path
business_name	VARCHAR(255)	Seller/business name
gst_id	VARCHAR(50)	GST identification number; UNIQUE
created_by	UUID / BIGINT	Creator account ID
created_by_type	VARCHAR(50)	SUPER_ADMIN or ADMIN
is_active	BOOLEAN	Seller account active/inactive
verification_status	VARCHAR(30)	PENDING / UNDER_REVIEW / APPROVED / REJECTED
created_at	TIMESTAMP	Seller creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

Constraints
UNIQUE(email) for seller login where business rules require global uniqueness. UNIQUE(gst_id) when one GST registration maps to one seller.

Part 1 - Seller & Customer Tables

5 seller_users — Tenant-scoped users

Customer/user accounts belonging to a seller.

Column	Type	Description
id	UUID / BIGINT	Primary key
seller_id	UUID / BIGINT	FK -> sellers.id; tenant scope
email	VARCHAR(255)	User login email
mobile_number	VARCHAR(20)	User mobile number
password_hash	VARCHAR(255)	Secure password hash
profile_photo	VARCHAR(500)	User profile photo URL/path
first_name	VARCHAR(100)	User first name
last_name	VARCHAR(100)	User last name
created_by	UUID / BIGINT	FK -> sellers.id (creator)
is_active	BOOLEAN	User active/inactive
created_at	TIMESTAMP	User creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

Required constraint: UNIQUE (seller_id, email)
Same email may exist under different sellers, but not twice under the same seller.

6 user_addresses — Multiple addresses per user

Separate address management. A seller user may have multiple addresses.

Column	Type	Description
id	UUID / BIGINT	Primary key
user_id	UUID / BIGINT	FK -> seller_users.id
address_line_1	VARCHAR(255)	Primary address line
address_line_2	VARCHAR(255)	Optional additional address line
city	VARCHAR(100)	City
state	VARCHAR(100)	State / region
pincode	VARCHAR(20)	Postal code
country	VARCHAR(100)	Country
address_type	VARCHAR(30)	HOME / WORK / OTHER
is_default	BOOLEAN	Default address flag
created_at	TIMESTAMP	Address creation time
updated_at	TIMESTAMP	Last update time

Part 1 - Verification & Access Tables

7 seller_verifications — MSME + document review

Seller onboarding and business verification data.

Column	Type	Description
id	UUID / BIGINT	Primary key
seller_id	UUID / BIGINT	FK -> sellers.id; UNIQUE for current record
msme_certificate	VARCHAR(500)	MSME certificate URL/path
gst_document	VARCHAR(500)	GST document URL/path
verification_status	VARCHAR(30)	PENDING / UNDER_REVIEW / APPROVED / REJECTED
reviewed_by	UUID / BIGINT	Reviewer account ID
reviewed_at	TIMESTAMP	Verification review time
rejection_reason	VARCHAR(500)	Reason for rejection
created_at	TIMESTAMP	Record creation time
updated_at	TIMESTAMP	Last update time

8 customer_care — Support account

Customer-care account. Access is permission-controlled.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Account display name
email	VARCHAR(255)	Login email
mobile_number	VARCHAR(20)	Mobile number
password_hash	VARCHAR(255)	Secure password hash; never store plain password
is_active	BOOLEAN	Account active/inactive
created_at	TIMESTAMP	Account creation time
updated_at	TIMESTAMP	Last update time
last_login_at	TIMESTAMP	Last successful login

Role & Permission Model

Table	Purpose
roles	Central role definitions
permissions	Atomic resources/actions
role_permissions	Maps roles to permissions
seller_user_roles	Assigns roles to seller users

Part 2 - Role & Permission Tables

9 seller_user_roles

UNIQUE (seller_user_id, role_id)

Assigns roles to seller users.

Column	Type	Description
id	UUID / BIGINT	Primary key
seller_user_id	UUID / BIGINT	FK -> seller_users.id
role_id	UUID / BIGINT	FK -> roles.id
created_at	TIMESTAMP	Assignment time

10 roles

Role definitions

Central role definition table.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(100)	Role name
description	VARCHAR(255)	Role description
created_at	TIMESTAMP	Creation time
updated_at	TIMESTAMP	Last update

11 permissions

Resource + action

Atomic authorization actions.

Column	Type	Description
id	UUID / BIGINT	Primary key
name	VARCHAR(150)	Permission name
resource	VARCHAR(100)	Resource being accessed
action	VARCHAR(50)	Action allowed
description	VARCHAR(255)	Permission description
created_at	TIMESTAMP	Creation time

12 role_permissions

UNIQUE (role_id, permission_id)

Maps roles to permissions.

Column	Type	Description
id	UUID / BIGINT	Primary key
role_id	UUID / BIGINT	FK -> roles.id
permission_id	UUID / BIGINT	FK -> permissions.id
created_at	TIMESTAMP	Assignment time

Part 3 - Session, Token & Data Isolation

13 refresh_tokens

Do not store raw token

Refresh-token storage and session revocation.

Column	Type	Description
id	UUID / BIGINT	Primary key
user_id	UUID / BIGINT	Authenticated account identifier
user_type	VARCHAR(50)	SUPER_ADMIN / ADMIN / ACCOUNTANT / SELLER / CUSTOMER_CARE / SELLER_USER
seller_id	UUID / BIGINT	Seller tenant ID; NULL for global accounts
token_hash	VARCHAR(500)	Hashed refresh token
expires_at	TIMESTAMP	Refresh token expiry
revoked_at	TIMESTAMP	Revocation time
created_at	TIMESTAMP	Token creation time
ip_address	VARCHAR(45)	Login IP
user_agent	TEXT	Browser/device information

14 jwt_tokens

Store hash / identifier only

JWT/session tracking for login and logout lifecycle.

Column	Type	Description
id	UUID / BIGINT	Primary key
user_id	UUID / BIGINT	Authenticated account identifier
user_type	VARCHAR(50)	Account role/type
seller_id	UUID / BIGINT	Tenant context; NULL for global accounts
access_token_hash	VARCHAR(500)	Hashed access-token identifier
token_type	VARCHAR(20)	Bearer
issued_at	TIMESTAMP	Issue time
access_token_expires_at	TIMESTAMP	Access-token expiry
refresh_token_expires_at	TIMESTAMP	Refresh-token expiry
revoked_at	TIMESTAMP	Revocation time
is_revoked	BOOLEAN	Revocation flag
ip_address	VARCHAR(45)	Login IP
user_agent	TEXT	Browser/device information
device_id	VARCHAR(255)	Optional device identifier
created_at	TIMESTAMP	Record creation time
updated_at	TIMESTAMP	Last update time

JWT Context

JWT claim	Purpose
user_id	Authenticated account identifier
user_type	SUPER_ADMIN / ADMIN / ACCOUNTANT / SELLER / CUSTOMER_CARE / SELLER_USER
seller_id	Tenant context; NULL for global accounts
role	Effective role used for authorization

TENANT ISOLATION
For every protected seller-scoped request, verify that the authenticated user seller_id matches the resource tenant. A user under Seller A must not be able to switch seller_id and access Seller B data.

Final constraints: UNIQUE (seller_id, email); UNIQUE (seller_user_id, role_id); UNIQUE (role_id, permission_id); UNIQUE (seller_id) for the current seller_verifications record; UNIQUE (gst_id) where one GST registration maps to one seller.